Setup, Run and Validation Guide

How to install the prototype, confirm it works, and validate its results on Windows

William A. Davis
CS 690 Graduate Research Project, Fall 2026
Advisor: Dr. Omar Ochoa
October 11, 2026

---

1. Before You Start

You need Python 3.11 or newer. Check by opening PowerShell and running `py --version`. If it is missing, install it from python.org and tick "Add python.exe to PATH" during setup. Java is needed only for the Maven validation in Section 5.

Every command in this guide must be run from inside the project folder, the one that contains pyproject.toml, README.md and the src folder. If you downloaded the project from GitHub as a ZIP file, this is the extracted folder whose name ends in -main. The easiest way to get there is to open the folder in File Explorer, type powershell in the address bar and press Enter, which opens PowerShell already inside it. If the commands below fail with "not recognized" or "does not appear to be a Python project" errors, PowerShell is in the wrong folder.

```
cd path\to\project-folder
```

2. One-Time Installation

Create a private Python environment for the project, allow PowerShell to run its activation script for this window only, activate it, and install the project with its test tools:

```
py -m venv .venv
Set-ExecutionPolicy -Scope Process -ExecutionPolicy Bypass
.venv\Scripts\Activate.ps1
pip install -e ".[dev]"
```

The prompt should now begin with (.venv). The execution-policy change lasts only until the window is closed, so it changes nothing permanently.

3. Every Time You Open a New PowerShell Window

```
cd path\to\project-folder
Set-ExecutionPolicy -Scope Process -ExecutionPolicy Bypass
.venv\Scripts\Activate.ps1
```

4. Confirm the Prototype Works

First run the automated tests. The expected result is "16 passed."

```
pytest
```

Next, have the tool read all four SBOMs:

```
sbomrisk inspect data\sboms\gitea-v1.21.0.cdx.json data\sboms\juice-shop-v20.2.0.cdx.json
data\sboms\pygoat-v2.0.1.cdx.json data\sboms\webgoat-v2026.4.cdx.json
```

The output should match the following table, and every project should report zero unreachable components and zero warnings.

SBOM	Components	Links	Direct	Max depth	Cycles
gitea-v1.21.0	231	733	110	3	Yes (normal for Go)
juice-shop-v20.2.0	689	1063	63	7	No
pygoat-v2.0.1	33	41	16	3	No
webgoat-v2026.4	191	380	37	8	No

Finally, export one project's dependency table and open it in Excel:

```
sbomrisk graph data\sboms\pygoat-v2.0.1.cdx.json -o pygoat.csv
start pygoat.csv
```

Each row is one package, with its depth (1 means PyGoat uses it directly), fan_in (how many packages depend on it) and fan_out (how many packages it depends on). As a spot check, Django should be at depth 1 and pycparser at depth 3, reached through cryptography → cffi → pycparser.

5. Validate the Results

Quick check against the saved reference outputs

These four commands compare the parser with the saved outputs of npm, pip, Go and Maven. Each should end with RESULT: PASS. The Maven result also lists eleven components that appear only in the SBOM, which the validation report explains.

```
python scripts\validate_graph.py npm data\sboms\juice-shop-v20.2.0.cdx.json
data\validation\juice-shop-npm-ls.json
python scripts\validate_graph.py pip data\sboms\pygoat-v2.0.1.cdx.json
data\validation\pygoat-pipdeptree.json
python scripts\validate_graph.py go data\sboms\gitea-v1.21.0.cdx.json data\validation\gitea-
go-list.json
python scripts\validate_graph.py maven data\sboms\webgoat-v2026.4.cdx.json
data\validation\webgoat-mvn-tree.txt
```

Independent Maven check

This optional check regenerates the Maven reference output on your own machine instead of using the saved copy. It needs Java 25, which can be installed with `winget install EclipseAdoptium.Temurin.25.JDK` or downloaded from adoptium.net. After installing, open a new PowerShell window and confirm that `java -version` reports 25. WebGoat includes its own Maven launcher, so Maven does not need to be installed separately.

```
$project = Get-Location
cd ..
Invoke-WebRequest https://github.com/WebGoat/WebGoat/archive/refs/tags/v2026.4.zip -OutFile
webgoat.zip
Expand-Archive webgoat.zip -DestinationPath .
cd WebGoat-2026.4
.\mvnw.cmd -B "-Denforcer.skip=true" dependency:tree "-Dscope=runtime" "-
DoutputFile=$project\mvn-tree.txt"
cd $project
python scripts\validate_graph.py maven data\sboms\webgoat-v2026.4.cdx.json mvn-tree.txt
```

The expected result is 179 of 179 components matched at the same depth, plus eleven components listed as appearing only in the SBOM. The validation report explains why those eleven appear and how to confirm the explanation.

6. Regenerating the SBOMs (Optional)

The script scripts/generate_sboms.sh rebuilds all four SBOMs from the tagged releases with pinned tool versions. It requires a Linux or macOS shell with git, Node.js, Go, Java with Maven, uv and the libpq development headers. It is not needed to run or validate the prototype; it exists so the dataset can be reproduced for the report.